

Clase 033 — Enumeración de servicios de red

Parte: 1 — Redes y seguridad de redes · Fuente: *The Hacker Playbook / OSCP methodology; docs oficiales de cada servicio* 🕒 Duración estimada: 130 min · Nivel: Intermedio

Objetivo

Profundizar la fase de **enumeración**: una vez identificados puertos y versiones, extraer toda la información útil de cada servicio (SMB, HTTP, DNS, SMTP, SNMP, FTP, LDAP) con herramientas especializadas. La enumeración exhaustiva es lo que separa un escaneo superficial de una evaluación real, y suele ser la fase que más hallazgos produce.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

- 1. **Enumerar** recursos compartidos, usuarios y políticas SMB.
- 2. **Explorar** servidores web: directorios, tecnologías, vhosts y cabeceras.
- 3. **Extraer** información de DNS (registros, transferencias de zona).
- 4. **Interrogar** SNMP, SMTP y FTP para obtener usuarios y configuración.
- 5. **Organizar** los hallazgos en notas estructuradas por servicio.
- 6. **Priorizar** vectores según el valor de la información obtenida.

Temas

#	Tema	Por qué importa
1	Metodología de enumeración	Orden y exhaustividad
2	SMB (139/445)	Muy rico en información en redes Windows
3	HTTP/HTTPS (80/443)	Mayor superficie de ataque
4	DNS (53)	Mapa de la infraestructura
5	SNMP (161/udp)	Configuración y a veces credenciales
6	SMTP (25)	Enumeración de usuarios
7	FTP/LDAP	Accesos anónimos y directorio

Definiciones y características

- **Enumeración**: proceso de interactuar con un servicio para extraer información detallada (usuarios, recursos, versiones, configuración) más allá de saber que existe.
- **Null session (SMB)**: conexión sin credenciales que en sistemas mal configurados revela usuarios y recursos.

- **Transferencia de zona (AXFR):** volcado completo de una zona DNS; si está mal permitida, expone todos los registros.
- **Community string (SNMP):** "contraseña" en claro (a menudo `public` / `private`) que da acceso de lectura/escritura a la MIB.
- **VHost (Virtual Host):** varios sitios en una misma IP diferenciados por cabecera `Host`; enumerarlos revela aplicaciones ocultas.

Herramientas y preparación

- **SMB:** `smbclient`, `enum4linux-ng`, `nmap scripts smb-*`, `crackmapexec`.
- **HTTP:** `whatweb`, `gobuster` / `feroxbuster`, `nikto`, `curl`.
- **DNS:** `dig`, `dnsenum`, `dnsrecon`.
- **SNMP:** `snmpwalk`, `onesixtyone`.
- **SMTP/FTP/LDAP:** `smtp-user-enum`, `ftp`, `ldapsearch`.
- Instalación típica en Kali: la mayoría vienen preinstaladas; si no, `sudo apt install smbclient snmp dnsutils gobuster nikto`.

 **Nota ética:** la enumeración es intrusiva y genera tráfico y logs. Realízala solo contra sistemas propios o dentro del alcance autorizado por escrito. Practica en tu laboratorio aislado.

Laboratorio guiado

1. SMB — recursos y sistema:

```
bash smbclient -L //192.168.56.101/ -N nmap -p445 --script smb-enum-shares,smb-enum-users,smb-os-discovery 192.168.56.101 enum4linux-ng -A 192.168.56.101
```

2. HTTP — tecnologías y directorios:

```
bash whatweb http://192.168.56.101/ gobuster dir -u http://192.168.56.101/ -w /usr/share/wordlists/dirb/common.txt -t 30 curl -sI http://192.168.56.101/ # cabeceras nikto -h http://192.168.56.101/
```

3. DNS — registros y transferencia de zona:

```
bash dig @192.168.56.1 lab.local ANY dig @192.168.56.1 lab.local AXFR # transferencia de zona dnsrecon -d lab.local -n 192.168.56.1
```

4. SNMP:

```
bash onesixtyone -c /usr/share/wordlists/snmp.txt 192.168.56.101 snmpwalk -v2c -c public 192.168.56.101
```

5. SMTP — enumeración de usuarios:

```
bash smtp-user-enum -M VRFY -U users.txt -t 192.168.56.101
```

6. FTP anónimo:

```
bash ftp 192.168.56.101 # usuario: anonymous, password: cualquiera
```

7. **Documenta** cada hallazgo en un archivo por servicio (`notas-smb.md` , `notas-http.md` , ...).

Ejercicios

1. Enumera los recursos SMB del objetivo y determina cuáles permiten acceso anónimo.
2. Con gobuster, encuentra al menos dos directorios no enlazados desde la página principal.
3. Intenta una transferencia de zona AXFR y explica el riesgo si tiene éxito.
4. Haz `snmpwalk` y localiza el nombre del sistema y la tabla de procesos.
5. Enumera usuarios por SMTP con VRFY y explica por qué muchos servidores lo desactivan.
6. Usa `whatweb` y `curl -I` para inventariar el stack tecnológico de un sitio.

Reto verificable

Elabora una "hoja de enumeración" de un host multiservicio de laboratorio que documente, por cada servicio abierto: versión, información sensible obtenida (recursos, usuarios, registros, directorios) y al menos un vector de ataque potencial priorizado. Entrega las notas y los comandos usados.

Criterio de aceptación: la hoja cubre todos los servicios abiertos que el revisor conoce, cada hallazgo es reproducible con el comando indicado y el vector priorizado es coherente con la información obtenida.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
<code>smbclient</code> "NT_STATUS_ACCESS_DENIED"	El recurso requiere credenciales; prueba null session <code>-N</code> o busca credenciales válidas
gobuster devuelve todo 200/403 igual	Falta filtrar por código o tamaño; usa <code>-b</code> para excluir códigos o <code>--exclude-length</code>
AXFR "Transfer failed"	La transferencia de zona está (correctamente) restringida; no es un fallo, es una buena práctica del servidor
<code>snmpwalk</code> sin respuesta	Community string incorrecta o SNMP filtrado; prueba <code>public</code> / <code>private</code> o versiones distintas
enum4linux muy lento	Muchas comprobaciones; usa opciones selectivas en lugar de <code>-A</code>

Preguntas frecuentes

 **¿Por qué SMB da tanta información?** Porque en redes Windows expone recursos, usuarios, políticas y el SO por diseño. Mal configurado (null sessions), regala un mapa de la organización.

 **¿Enumeración y escaneo son lo mismo?** No. El escaneo dice qué hay (puertos/servicios); la enumeración interactúa con cada servicio para extraer información detallada y utilizable.

 **¿La enumeración es detectable?** Mucho. Genera numerosas conexiones y peticiones que un IDS/SIEM registra. Por eso solo se hace dentro del alcance autorizado.

 **¿Qué hago con tanta información?** Organízala por servicio y prioriza vectores según impacto y facilidad. Unas buenas notas de enumeración son la base de las fases de explotación posteriores.

Referencias

- Nmap NSE scripts (smb-, *http*-, dns-*). <https://nmap.org/nsedoc/>
- OWASP Testing Guide — Information Gathering. <https://owasp.org/www-project-web-security-testing-guide/>
- gobuster. <https://github.com/OJ/gobuster>
- enum4linux-ng. <https://github.com/cddmp/enum4linux-ng>

Siguiente clase

Clase 034 - Firewalls: tipos, iptables y nftables